

Part 4: System password hashes

Ethical and authorized use: use only ../data/linux_hashes.txt. The parser does not access /etc/shadow. Never obtain or test another person's hashes.

Run `python3 analyze_shadow_hash.py ../data/linux_hashes.txt`. A shadow-style value uses \$identifier\$salt-or-parameters\$verifier; the identifier selects the password-hashing scheme. Classify this exercise as online or offline and justify your answer.

Purpose and learning objectives

Linux does not normally store account passwords directly. A protected account database stores a modular hash string containing an algorithm identifier, salt or parameters, and verifier. This part uses one supplied fictional record; it does not read the host or container account database.

After completing this part, you should be able to:

- recognize the colon-separated shape of a shadow-style account line;
- parse the \$identifier\$salt\$verifier password field;
- map identifier \$6\$ to SHA-512-crypt;
- distinguish parsing a verifier from recovering a password; and
- classify a local wordlist check as an offline attack.

Record structure

The supplied line has the simplified shape:

```
account:$id$salt$verifier:password-change fields...
```

The account name is not secret. The algorithm identifier tells the verifier which function to run, and the salt must be available to repeat verification. The long final value is the verifier, not encrypted plaintext. Remaining colon fields describe password-aging policy and are outside this parser's core task.

Tasks

1. Display ../data/linux_hashes.txt and identify colon-separated fields.
2. Run `analyze_shadow_hash.py` and map its dictionary output back to the line.
3. Explain why the parser needs no password and performs no guesses.
4. Optionally run John with only the supplied file and small course wordlist.
5. Use `john --show` to review the local result.
6. Classify parsing and cracking separately as online or offline activities.

Python files and usage examples

`'analyze_shadow_hash.py'`

```
cd /workspace/labs/lab01/part4_system_hashes
python3 analyze_shadow_hash.py ../data/linux_hashes.txt
```

Expected output has this structure:

```
{'account': 'student_...', 'id': '6', 'algorithm': 'SHA-512-crypt',
 'salt_or_parameters': '...', 'verifier': '...'}
```

The `$6$` identifier selects SHA-512-crypt. The salt and verifier are stored data; neither field is the plaintext password. Notice that the script accepts an explicit local filename and never opens `/etc/shadow` automatically.

The positional argument is required. Running the help command documents it without parsing a file:

```
python3 analyze_shadow_hash.py --help
```

Optional local cracking command:

```
john --wordlist=../data/lab01-small.txt ../data/linux_hashes.txt
```

To display John the Ripper's result for this supplied file, run:

```
john --show ../data/linux_hashes.txt
```

Runtime and exact status messages can vary. The important observation is that all guesses are checked locally, without sending login attempts to a service.

Use only the supplied synthetic file. If an instructor separately provides a Victim Ubuntu VM, it must be deliberately vulnerable and connected only to an isolated host-only network. Worksheet (manual observation only): list the VM's instructor-provided address, visible services, evidence of isolation, and which service would authenticate users. Do not scan arbitrary addresses.

Completion criteria and report evidence

You have completed Part 4 when the parser identifies the fictional account, algorithm, salt, and verifier without accessing `/etc/shadow`. If you perform the optional John step, record its status and candidate count but do not publish the recovered password. Include your online/offline classification and its justification. The optional VM worksheet is required only when assigned by the instructor.

Checkpoint questions

1. Does the hash format reveal the plaintext?
2. Which fields must be stored so legitimate verification remains possible?
3. Is this an online or offline activity? What evidence supports your answer?
4. Why must an optional Victim VM use an isolated host-only network?